

Atbalsts platformas drošības gatavība

Vadības kopsavilkums krīzes centra vadībai

Secinājums Platformu var droši demonstrēt, ja tā ir skaidri marķēta kā demonstrācijas vide. Apstiprinātais laidziens, minimāla publiskā diagnostika, piekļuves kontrole, procesu atjaunošanās un atgriešanās uz iepriekšējo versiju ir pārbaudīta. Reālai krīzes vadībai vēl jāievieš individuāla identitāte, perimetra aizsardzība, darbības nepārtrauktība un cilvēku drošības vārti.

93% Demonstrācijas gatavība

Augsta. Visi būtiskie demonstrācijas kontroles punkti ir praktiski pārbaudīti.

66% Ražošanas drošības gatavība

Vidēja. Vidējais novērtējums desmit kontroles jomās; tas nav audits vai sertifikācija.

Ko var droši parādīt šodien

✓ Kontrolēts laidziens

PR #73 apvienots pēc sekmīgas CI pārbaudes; publiski darbojas tieši apstiprinātais main komits 664b5e5.

✓ Pārbaudīta atkopšana

Lietotne un tunelis atjaunojas pēc procesa kļūmes; praktiski izmēģināta atgriešanās uz iepriekšējo versiju.

✓ Minimāla publiskā virsma

/api/health atklāj tikai stāvokli un laidiena SHA; publiskais notikumu API neizdod iekšējos laukus.

✓ Aizsargāta operatīvā piekļuve

Centra diagnostika un datu atsveidzināšana anonīmam lietotājam nav pieejama. MI npublicē un nenosūta cilvēkus patstāvīgi.

Pašreizējā aizsardzības arhitektūra

Publiskais lietotājs → Cloudflare → drošs tunelis → Atbalsts lietotne → dati un MI pakalpojumi

Cloudflare samazina tiešu servera ekspozīciju, taču pašreiz ir viena lokāla izcelsmes instance. Worker nav publiskā domēna izcelsmes serveris, un Vite priekšskatījuma serveris ir pieļaujams tikai demonstrācijai.

Galvenie uzbrukuma ceļi

PROGRAMMATŪRA

API datu izguve, pieprasījumu plūdi un izmaksu palielināšana, sesiju zādzība, promptu injekcija, ļaunprātīgi faili un piegādes ķēdes kompromitēšana.

CILVĒKI UN PROCESS

Pikšķerēšana, kopīgi piekļuves dati, uzdošanās par partneri, kļūdaina publicēšana, iekšēja ļaunprātība, nogurums un neizmēģināta atkopšana pēc incidenta.

Ieviešanas robežas

01 Demonstrācija

VAR IZMANTOT TAGAD

Sintētiski dati, publiskā informācija, tikai lasāma karte un Centra skats. Kopīgā parole jānosauca kā apzināts demonstrācijas ierobežojums.

02 Kontrolēts pilots

AR NOSACĪJUMIEM

Pirms personas datiem vajadzīgi individuāli konti, MFA, datu ietekmes novērtējums, glabāšanas noteikumi, failu karantīna un perimetra kontroles.

03 Darbs reālā krīzē

VĒL NEATĻAUT

Nepieciešama augsta pieejamība, brīdinājumi, incidentu un rezerves kopiju mācības, kā arī misiju kompetences, risks, piekrišanas un četru acu pārbaudes.

Produktu nošķiršana

Sākt ar publisko informāciju un tikai lasāmu karti. Tas ir drošākais atsevišķais produkts. Iedzīvotāju ziņojumus var pievienot kontrolētā pilotā pēc datu, failu un perimetra prasību izpildes.

Saglabāt izolētus vadības un nosūtīšanas moduļus.

Vadības centrs paliek demonstrācijas režīmā, bet misijas un brīvprātīgo nosūtīšanu nepalaiž līdz drošības vārtiem. MI paliek tikai padomdevēja lomā.

Drošības stāvoklis un ceļš uz ieviešanu

Procenti rāda kontroles gatavību pēc koda, publiskās vides un praktisko pārbaudžu stāvokļa. Tie palīdz noteikt prioritātes, bet neaizstāj neatkarīgu auditu, juridisku atzinumu vai sertifikāciju.

STIPRĀKĀS JOMAS

Publiskā virsma 92%

Minimāla diagnostika un noteikts publisko datu lauku saraksts.

Izlaidumi un atkopšana 90%

Precīzs SHA, nemaināmi laidieni, automātiska atjaunošanās un pārbaudīta atgriešanās.

MI un ārkārtas loģika 82%

Ārkārtas atbilde pirms MI; publicēšanu un rīcību apstiprina cilvēks.

Repozitorijs un piegādes ķēde 74%

CI, 32 pārbaudes, kritisku atkarību vārti, Dependabot un CODEOWNERS.

Dati un Supabase 65%

Servera atslēgas, noturīga glabātuve, datu minimizācija un validācija.

JĀNOSTIPRINA PIRMS REĀLAS LIETOŠANAS

Identitāte un sesijas 58%

Droši sīkfaili un izcelsmes pārbaudes; vēl nav individuālu kontu, MFA un sesiju atsaukšanas.

Faili 55%

Privāta glabāšana un tipa, izmēra un īpašnieka pārbaudes; nav karantīnas un ļaunprogrammatūras skenēšanas.

Uzraudzība un incidenti 55%

Procesi tiek uzraudzīti; trūkst brīdinājumu, incidentu plāna un regulāru mācību.

Cloudflare perimetrs 45%

Tunelis un lietotnes ierobežojumi darbojas; pielāgoti WAF un ātruma ierobežojumi vēl nav ieviesti.

Misijas un brīvprātīgie 45%

Ir cilvēka apstiprinājums un audits; nav pilnu kompetences, riska un piekrišanas vārtu.

Četri lēmumi pirms nākamā posma

01 Perimetrs un koda pārvaldība

Cloudflare un GitHub administratori · 17.09.2026

Ieviest MI API un pieteikšanās ātruma ierobežojumus, pārskatīt Security Events un aizsargāt main ar obligātu PR, verify un CODEOWNERS apstiprinājumu.

02 Identitāte dati un faili

Produkta privātuma un drošības īpašnieki · Pirms personas datu pilota

Ieviest individuālus kontus, MFA un sesiju atsaukšanu; pabeigt datu karti, NIDA, glabāšanas un dzēšanas noteikumus un failu karantīnu.

03 Darbības nepārtrauktība

Infrastrukturā īpašnieks · 10.10.2026

Aizstāt Vite priekšskatījumu ar atbalstītu ražošanas izpildvidi, pievienot pieejamības brīdinājumus un pārbaudīt otro izcelsmes instanci un rezerves kopiju atjaunošanu.

04 Cilvēku un misiju drošība

Produkta un operāciju vadība · Pirms reālu misiju palaišanas

Ieviest kompetences, riska un piekrišanas pārbaudes un četru acu principu. MI paliek padomdevējs bez publicēšanas vai cilvēku nosūtīšanas tiesībām.

Atbilstības ceļš

Obligātā piemērojamība Personas datiem piemēro VDAR. Atsevišķi jānosaka Nacionālā kiberdrošības likuma, NIS2 un MK noteikumu Nr. 397 piemērojamība, Kiberneturības akta prasības katram tirgū laistam produktam ar digitāliem elementiem un MI akta prasības pēc MI faktiskās lomas.

Ieviešanas ietvars NIST CSF 2.0 organizācijas risku pārvaldībai un OWASP ASVS 5.0 lietotnes kontrolēm. ISO/IEC 27001 sertifikāciju apsvērt, ja to prasa iepirkums vai tirgus.

Primārie avoti [VDAR](#) · [Nacionālās kiberdrošības likums](#) · [MK Nr. 397](#) · [Kiberneturības akts](#) · [MI akts](#) · [NIST CSF 2.0](#) · [OWASP ASVS 5.0](#)

Ieteicamais sapulces lēmums

Apstiprināt demonstrāciju pašreizējā vidē ar skaidri nosauktiem ierobežojumiem un sintētiskiem datiem. **Kontrolētu personas datu pilotu sākt tikai pēc 1. un 2. lēmuma izpildes. Reālu krīzes operāciju un cilvēku nosūtīšanu atļaut tikai pēc 3. un 4. lēmuma izpildes un praktiskām incidentu mācībām.**

Pierādījumu ieraksts PR #73; CI izpilde 34499895675; publiskais laidiens 664b5e58bde2fe39287b806c5606eb573a78c1ae; publiskās un anonīmās pārbaudes 2026. gada 10. septembrī.